NexaPair × KAYAK STRATEGIC ADVISORS

SECURITY WHITE PAPER



WHITE PAPER · NOVEMBER 2026

Security, as it stands today

What is true of NexaPair's security now, control by control, marked Live, Roadmap or To be confirmed.

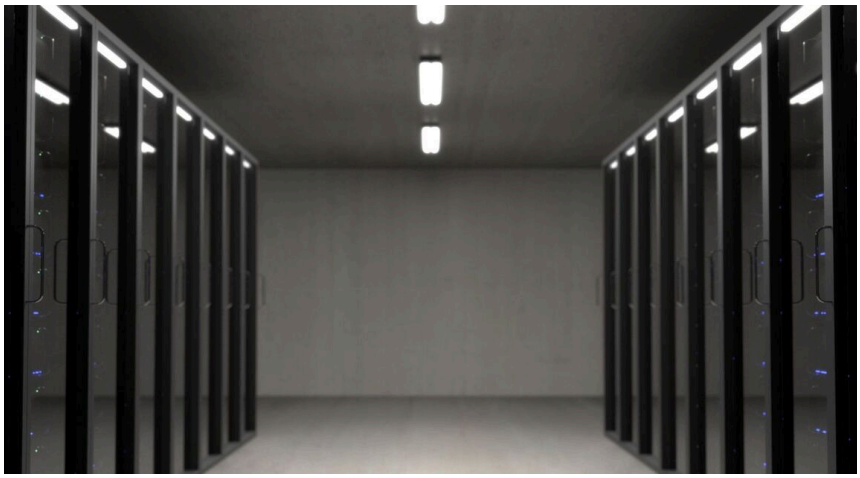
Published by NexaPair and Kayak Strategic Advisors Private Limited · nexapair.ae · NP-WP-2026-02

November 2026

CONTENTS

In this paper

· At a glance 3
01 Hosting and architecture 4
02 Identity, data, AI, development and resilience 5
07 Control register 6
08 Still being finalised, and shared responsibility 7



The platform runs in a UAE cloud region, so records can stay in the country. Photo: Pexels.

HOW TO READ THIS PAPER

We state only what is true today. Every control carries one of three labels.

Live	In production now and tested on every release.
Roadmap	Planned; not available yet. We do not sell roadmap items as features.
To be confirmed	Built or in place, with details still being finalised or depending on a third party.

STANDARDS

Controls are aligned to ISO/IEC 27001 and SOC 2. Certification is not yet held, and we do not claim it.

This paper is for information. The contract and its security schedule are what bind.

AT A GLANCE

Security in four numbers

UAE
North: the cloud region where production runs, so data can stay in the country.

5
roles decide who sees and changes what; API keys are scoped the same way.

256
bit AES-GCM encryption for customer-supplied AI provider keys.

0
personal data sent to outside AI models: it is removed before any call.

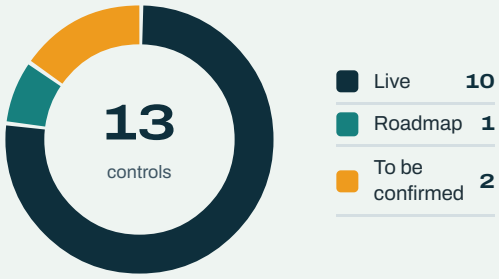
Summary

NexaPair holds sensitive information about the companies its clients depend on: ownership, screening results, contracts and decisions. We built the platform on the assumption that a regulator, an auditor or a client's security team will ask how each of those records is protected, and that the answer has to be specific.

Every organisation's records are isolated from every other organisation's. Access follows roles, can require multi-factor authentication and can come from the client's own identity provider. Every change is recorded in an audit trail the client can export. The platform runs in a UAE cloud region, and its code is scanned on every change.

Where something is not finished, we say so. Section 08 lists what is still being finalised.

CONTROLS BY STATUS



The full register is in section 06.



01

HOSTING AND ARCHITECTURE

Built and run in the UAE

Production runs entirely in a UAE cloud region. Each part does one job and holds only the access it needs.

MICROSOFT AZURE · UAE NORTH

Web and API
Container apps behind managed TLS certificates; only HTTPS reaches them.

Worker
Scheduled checks, screening and notifications, isolated from the web tier.

File scanning
Every upload is scanned for malware before anyone can open it.

Database
Managed PostgreSQL; every record carries its organisation.

Secrets
Keys and passwords held in Key Vault, read by managed identities.

Backups
Database backups to write-once storage, with restore tests.

Email
Platform email sent through a managed service in Azure.

Monitoring
Central logs and health checks, with a self-healing job every 15 minutes.

Deployments are automated from version control. Infrastructure is defined as code, so the same reviewed definition builds every environment, and the deployment identity signs in with short-lived federated credentials rather than stored passwords.

Staging and production are separate environments with separate databases, key vaults and identities. Nothing in production is changed by hand.

IaC
every environment built from reviewed code

OIDC
short-lived deploy credentials, no stored passwords

2
separate environments: staging and production

15 min
self-healing checks

02 · IDENTITY AND ACCESS

The right people, and only them

Five roles decide who sees and changes what, and API keys are scoped the same way. Clients can sign in through Entra ID, Okta, AD FS or any OIDC or SAML 2.0 provider, with group-to-role mapping.

Multi-factor authentication supports authenticator-app codes, passkeys and recovery codes, and can be enforced per organisation, role and duty. UAE PASS sign-in is built and switched off until each organisation completes onboarding with TDRA.

SEPARATION OF DUTIES

The person who raises a decision is not the person who approves it, and both are recorded.

03 · DATA PROTECTION

Your records stay yours

Every record carries its organisation, and every query is filtered by it. Ten registers export to CSV and JSON at any time, audit trail included, so a client is never locked in.

Data travels over TLS and is encrypted at rest by the hosting provider. Signed webhooks carry an HMAC-SHA256 signature with a timestamp on every event, so a receiving system can prove a message came from NexaPair and was not replayed.

RESIDENCY

Deployable in a UAE cloud region, so records can stay in the country, in line with CBUAE Article 8.9 on the master system of record.

RBAC five roles, scoped API keys

SSO OIDC and SAML 2.0

MFA codes, passkeys, recovery codes

Audit who changed what, and when

04 · AI GOVERNANCE

People decide; AI assists

Personal data is removed before any request reaches an outside AI model, and NexaMind runs on the platform itself. AI outputs are labelled and logged.

05 · SECURE DEVELOPMENT

Scanned on every change

Code, dependency, secret, container and web scanning on every change and weekly, with automatic update pull requests.

06 · RESILIENCE

Recover, and prove it

Backups go to write-once storage and are restore-tested. A self-healing job retries failed deliveries and catches up missed work every 15 minutes.

07 · CONTROL REGISTER

Every control, and its status

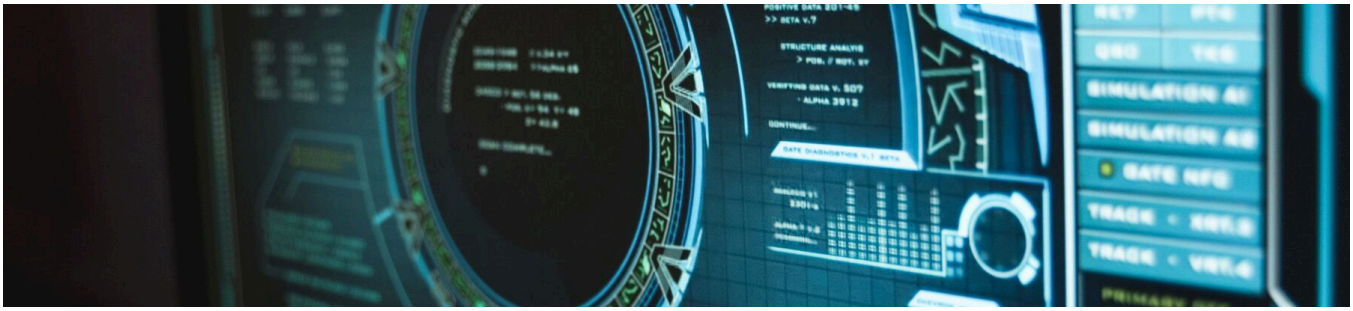
Control	Status	What it does
Role-based access (RBAC)	Live	Five roles decide who sees and changes what; API keys are scoped the same way.
Tenant isolation	Live	Every record carries its organisation, and every query is filtered by it.
Audit trail	Live	Who changed what, and when, exported to CSV or JSON.
Export and portability	Live	Ten registers export to CSV and JSON at any time, audit trail included.
Secrets: AI provider keys	Live	Encrypted with AES-256-GCM; personal data is removed before any AI call.
UAE data residency	Live	Deployable in a UAE cloud region, so records can stay in the country.
Signed webhooks	Live	HMAC-SHA256 signature with a timestamp on every event.
Encryption in transit and at rest	To be confirmed	TLS in transit; at-rest encryption by the hosting provider. Details: being finalised.
Vulnerability management	Live	Code, dependency, secret, container and web scanning on every change and weekly, with automatic update pull requests. Penetration test: being scheduled.
Single sign-on: OIDC and SAML	Live	Sign in with Entra ID, Okta, AD FS or any OIDC or SAML 2.0 provider, with group-to-role mapping.
UAE PASS sign-in	To be confirmed	Built and switched off until each organisation completes UAE PASS onboarding with TDRA.
Multi-factor authentication	Live	Authenticator-app codes, passkeys and recovery codes, enforceable per organisation, role and duty.
SCIM provisioning	Roadmap	Users and roles kept in step with your directory.

ASK FOR THE EVIDENCE

For any control marked Live we can show the configuration or test result behind it during due diligence, under NDA where needed.

CHANGES

When a status changes, this paper and the Trust page on nexapair.ae change with it.



Controls are aligned to ISO/IEC 27001 and SOC 2; certification is not yet held. Photo: Pexels.

08 · STILL BEING FINALISED

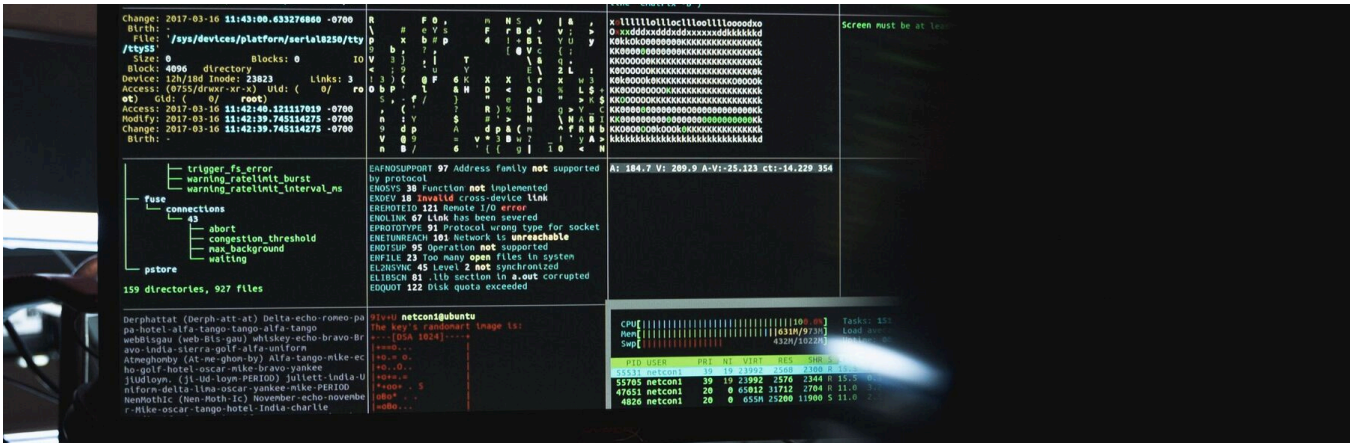
What we do not claim yet

Certifications	Not yet held. Controls are aligned to ISO/IEC 27001 and SOC 2.
Independent penetration test	Being scheduled with an independent firm; the report summary will be shared under NDA.
Encryption details	At-rest encryption by the hosting provider; the key-management statement is being finalised.
Sub-processors	The list is being finalised for the data processing agreement.
Data processing agreement	Standard agreement being finalised.
Retention and deletion	Policy being finalised; exports are available at any time.

09 · SHARED RESPONSIBILITY

Who does what

Area	Owner	Support
Users, roles and MFA policy	**Client**	Platform enforces
Identity provider and SSO groups	**Client**	Platform maps groups to roles
Data entered and decisions taken	**Client**	Platform records and audits
Platform, hosting and patching	**NexaPair**	—
Backups and restore tests	**NexaPair**	—
Incident notification to clients	**NexaPair**	Client notifies its regulator



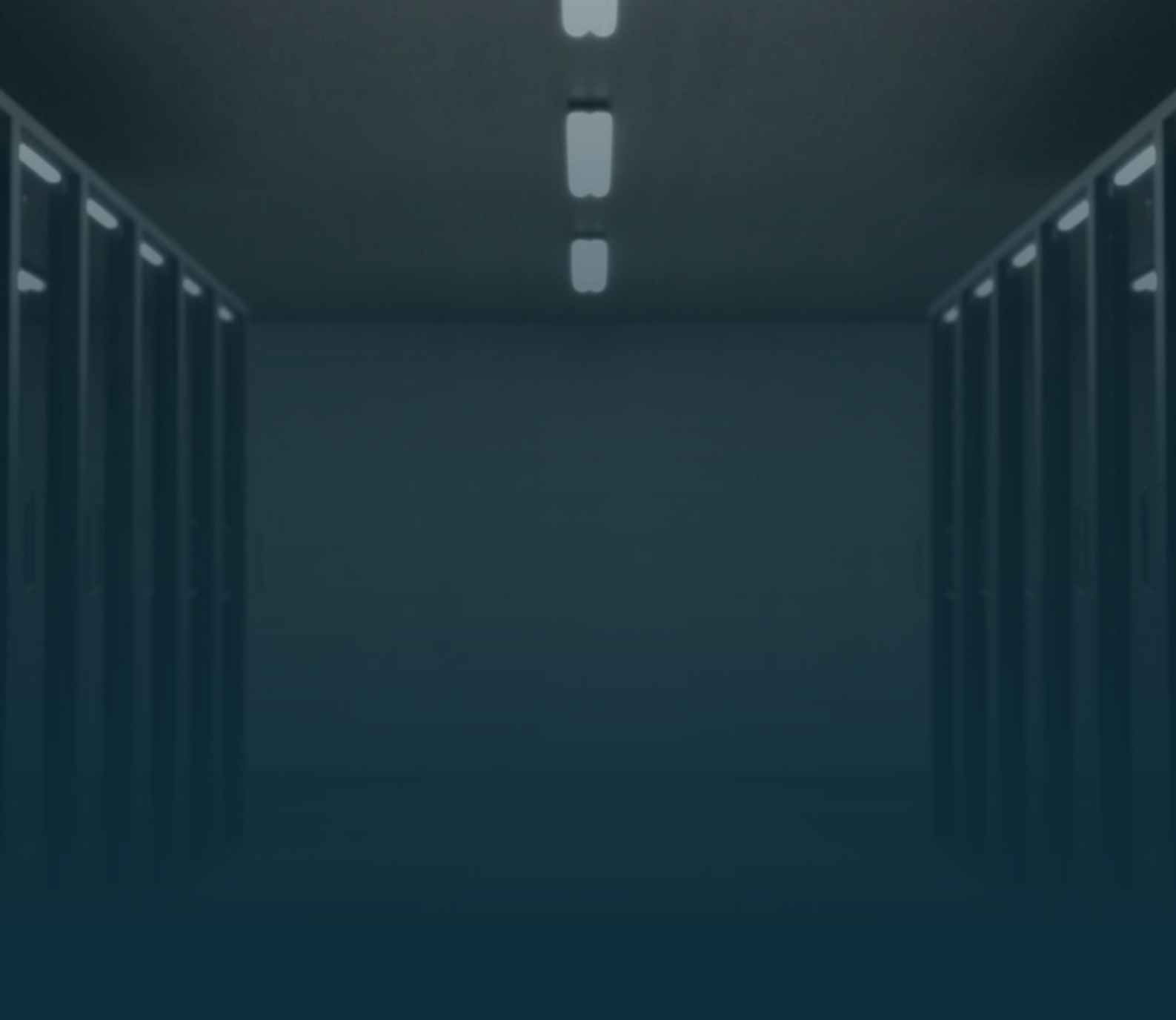
Security reports are welcome: see /.well-known/security.txt on nexapair.ae. Photo: Pexels.

SECURITY AND AUDIT QUESTIONS

advisory@kayaksa.com

REPORT A VULNERABILITY

See /.well-known/security.txt on nexapair.ae.



NexaPair × KAYAK STRATEGIC ADVISORS

ABOUT NEXAPAIR

NexaPair is a third-party risk management platform for the UAE, hosted in a UAE cloud region. It verifies, screens, monitors and scores the companies an institution depends on, and keeps the evidence a regulator expects.

ABOUT KAYAK STRATEGIC ADVISORS

Kayak Strategic Advisors Private Limited (CIN U70200MH2026PTC477060) is a management consultancy based in Mumbai. It builds and runs NexaPair, pairing advisory judgement with software.

OFFICE
Mumbai, Maharashtra, India

EMAIL
advisory@kayaksa.com

PHONE
+91 7710 828 028

Important notice. This publication contains general information only. It is not legal, regulatory, tax or other professional advice and should not be relied on as such; regulations are summarised and paraphrased and may have changed. Refer to the official texts (for the CBUAE, rulebook.centralbank.ae) and take advice for your organisation. Responsibility for compliance stays with each institution. You may share this publication in full with attribution.

Photography: Pexels (pexels.com/photo/5380642, 325229, 5380664), used under the Pexels licence. NexaPair and the NexaPair logo are marks of Kayak Strategic Advisors Private Limited. © 2026 Kayak Strategic Advisors Private Limited. All rights reserved.